

Tema 7.

Esquema Nacional de Seguridad.

1

INTRODUCCIÓN

2

ORIGEN DEL ENS

3

ESQUEMA NACIONAL DE SEGURIDAD

4

PRINCIPOS BÁSICOS DE ENS (CAPÍTULO 2)

5

REQUISITOS MÍNIMOS DE SEGURIDAD (CAPÍTULO 3)

6

COMUNICACIONES ELECTRÓNICAS (CAPÍTULO 4)

7

AUDITORÍA DE LA SEGURIDAD (CAPÍTULO 5)

8

ESTADO DE SEGURIDAD DE LOS SISTEMAS (CAPÍTULO 6)

1. INTRODUCCIÓN

- “Si usted cree que la tecnología puede resolver sus problemas de seguridad, entonces ni entiende usted los problemas ni entiende la tecnología.” (*Bruce Schneier*)
- “Las organizaciones gastan millones de dólares en firewalls y dispositivos de seguridad, pero tiran el dinero porque ninguna de estas medidas cubre el eslabón más débil de la cadena de seguridad: la gente que usa y administra los ordenadores” (*Kevin Mitnick*)

Es necesaria una estrategia de seguridad

Ley 11/2007, de 22 de Junio, de acceso electrónico de los ciudadanos a los Servicios Públicos (LAECSP)

• **Permite :**

- Garantizar la provisión de servicios de las AAPP hacia los ciudadanos por medios telemáticos y electrónicos
- Mejorar las condiciones actuales en la prestación de esos mismos servicios en su modalidad presencial.

El **Real Decreto 311/2022**, de 3 de mayo, por el que se regula el **Esquema Nacional de Seguridad (ENS)**

• **Permite :**

- Garantizar la provisión de servicios de las AAPP hacia los ciudadanos por medios telemáticos y electrónicos
- Mejorar las condiciones actuales en la prestación de esos mismos servicios en su modalidad presencial.

2. ORIGEN DEL ENS

- **ENS como complemento de LAECSP**

Visión desde la Ley Acceso Electrónico (LAECSP)

- **Dar servicio de puertas afuera:**

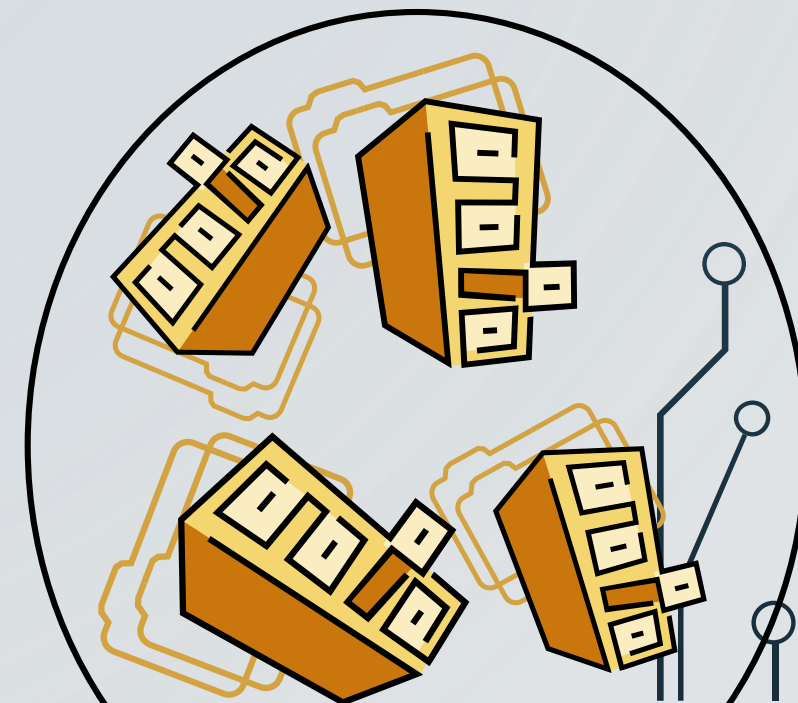
- Actuación no presencial :
- Internet / Intranet

Visión desde la Ley del ENS

- **Puertas adentro: reorganización interna**

- Reingeniería de procesos
- Cambios en aplicaciones informáticas

Nuevos hábitos en SEGURIDAD



3. ESQUEMA NACIONAL DE SEGURIDAD

- El ENS establece los principios y requisitos de una política de seguridad que permita la adecuada protección de la información en la utilización de los medios electrónicos en el acceso de los ciudadanos a los Servicios Públicos.
- Los **objetivos** del ENS son:
 - Crear las **condiciones necesarias de confianza** en el uso de los medios electrónicos.
 - Introducir los elementos en **materia de seguridad** de las tecnologías de la información.

3. ESQUEMA NACIONAL DE SEGURIDAD

- Según el ENS:
 - La seguridad ha de ser un proceso integral, basada en riesgos.
 - La estrategia de protección ha de estar constituida por múltiples capas de seguridad.
 - Define auditorías de seguridad con una periodicidad mínima de 2 años.

¿QUIÉN DEBE CUMPLIR EL ENS?

- AAPP, incluidas las siguientes entidades:
 - Administración General del Estado.
 - Las Administraciones de las Comunidades Autónomas.
 - Las entidades que integran la Administración Local.
 - Las entidades de derecho público pertenecientes al sector público institucional.
 - Entidades de derecho privado pertenecientes al sector público institucional.
 - Entidades de derecho privado vinculadas o dependientes de las comunidades autónomas.
 - Entidades de derecho privado vinculadas o dependientes de la administración de las entidades locales.
 - Universidades públicas

¿QUIÉN DEBE CUMPLIR EL ENS?

- AAPP, incluidas las siguientes entidades:
 - Corporaciones de derecho público.
 - Órganos constitucionales y órganos legislativos y de control autonómicos.
 - Entidades de derecho privado y fundaciones.
- **EMPRESAS DEL SECTOR PRIVADO:**
- Proporcionan soluciones tecnológicas o servicios comprendidos dentro del ámbito objetivo de aplicación del Esquema Nacional de Seguridad.



- Las soluciones o servicios deberán obtener el certificado de conformidad según *Guía CCN-STIC-809 “Declaración y Certificación de Conformidad con el ENS y Distintivos de Cumplimiento”*.

- **Modelo declaración conformidad con el ENS y distintivo**



- **Modelo de certificación conformidad con el ENS y distintivo**



¿CUÁL ES EL ÁMBITO DE APLICACIÓN DEL ENS?

- La LAECSP regula los aspectos básicos de la utilización de las tecnologías de la información en tres ámbitos:
 - **La actividad Administrativa.**
 - **Las relaciones entre las AAPP.**
 - **Las relaciones de los ciudadanos con las AAPP.**
- Por tanto, el ENS **tendrá aplicación sobre estas actividades y los activos involucrados en ejecutarlas.**
- **Excluidas** las actividades que las AAPP lleven a cabo en **régimen de derecho privado o que** no estuvieren dedicados a gestionar las funciones o competencias propias de la entidad pública de que se trate.

¿QUÉ SISTEMAS DEBEN CUMPLIR EL ENS?

- Según la Guía CCN-STIC-830 Ámbito Aplicación ENS sería de aplicación en todo lo relativo a:
 - Facilitar a los ciudadanos a relacionarse electrónicamente con las AAPP.
 - Facilitar por medios electrónicos en el Procedimiento Administrativo.
 - Facilitar el uso de medios de identificación y firma electrónica a los interesados.
 - Registros electrónicos.
 - Archivos electrónicos
 - Funcionamiento electrónico de las administraciones.

EJEMPLOS:

**ARCHIVO
ELECTRÓNICO**

**GESTIÓN VACANTES
HOSPITAL**

**GESTIÓN
EXPEDIENTES
ACADÉMICOS**

**CITAS
OBTENCIÓN DNI**

**PROCEDIMIENTOS
SANCIONADORES**

**PADRÓN
AYUNTAMIENTO**

**PERFIL
CONTRATANTE**

**GESTIÓN
CONTABILIDAD**

GESTIÓN RRHH

**TRAMITACIÓN
LEGISLATIVA**

GESTIÓN TRIBUTARIA

SISTEMAS SCADA

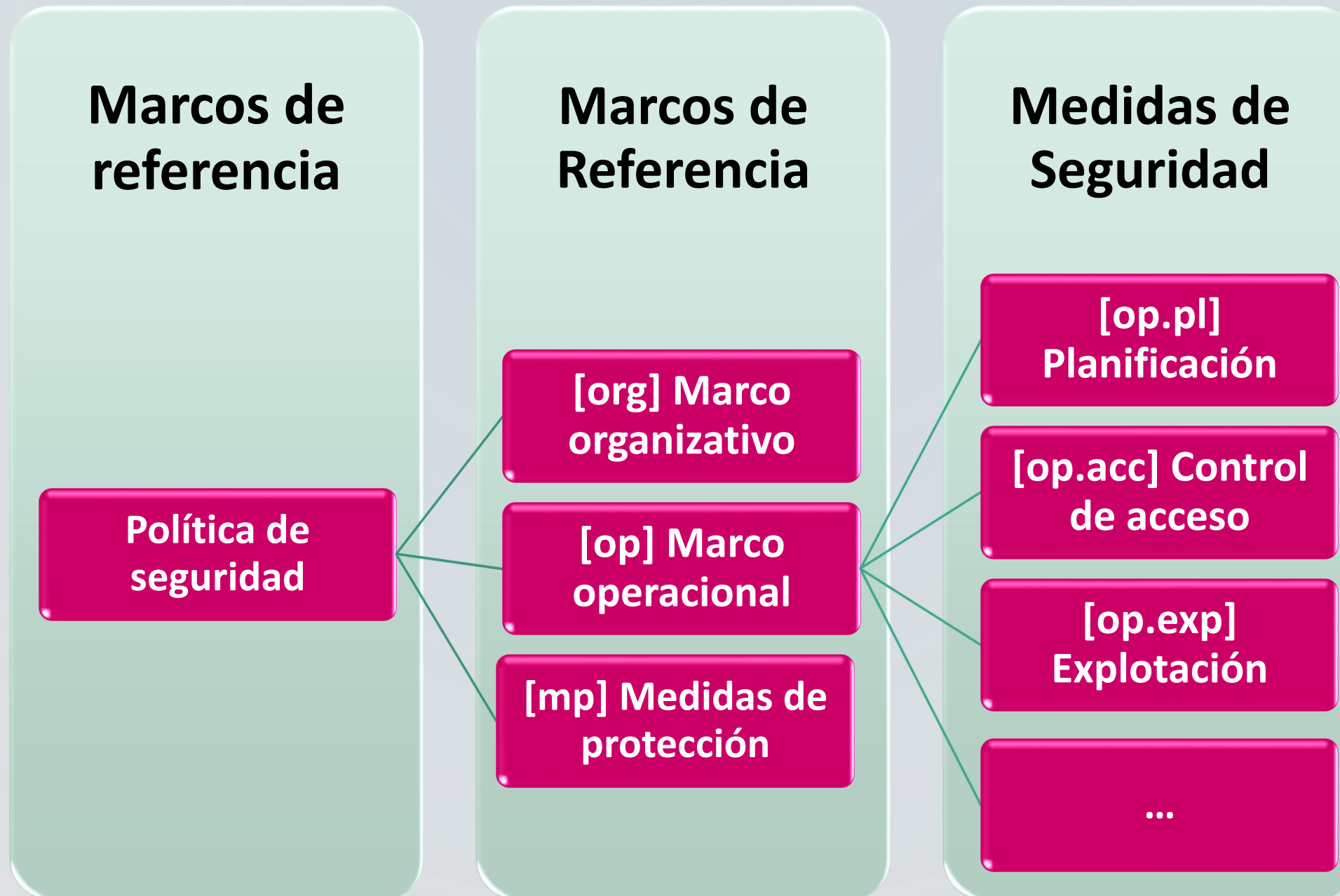
¿QUÉ SISTEMAS QUEDAN EXCLUIDOS?

- Los sistemas no relacionados con el ejercicio de derechos (interesados, ciudadanos, empleados), ni con el cumplimiento de deberes por medios electrónicos, ni con el acceso por medios electrónicos de los ciudadanos a la información y al procedimiento administrativo.

¿QUÉ HACER PARA CUMPLIR CON ENS?

- Para abordar el proyecto de adecuación al ENS, se deberá aplicar una metodología que considere los siguientes pasos:
 1. Establecer una política de seguridad.
 2. Identificar los sistemas afectados.
 3. Determinar los riesgos sobre los sistemas afectados.
 4. Categorizar los sistemas afectados.
 5. Insuficiencias del sistema.
 6. Aplicar los controles correspondientes, de los previstos en el Anexo II del ENS.

CONTROLES PREVISTOS EN EL ANEXO II



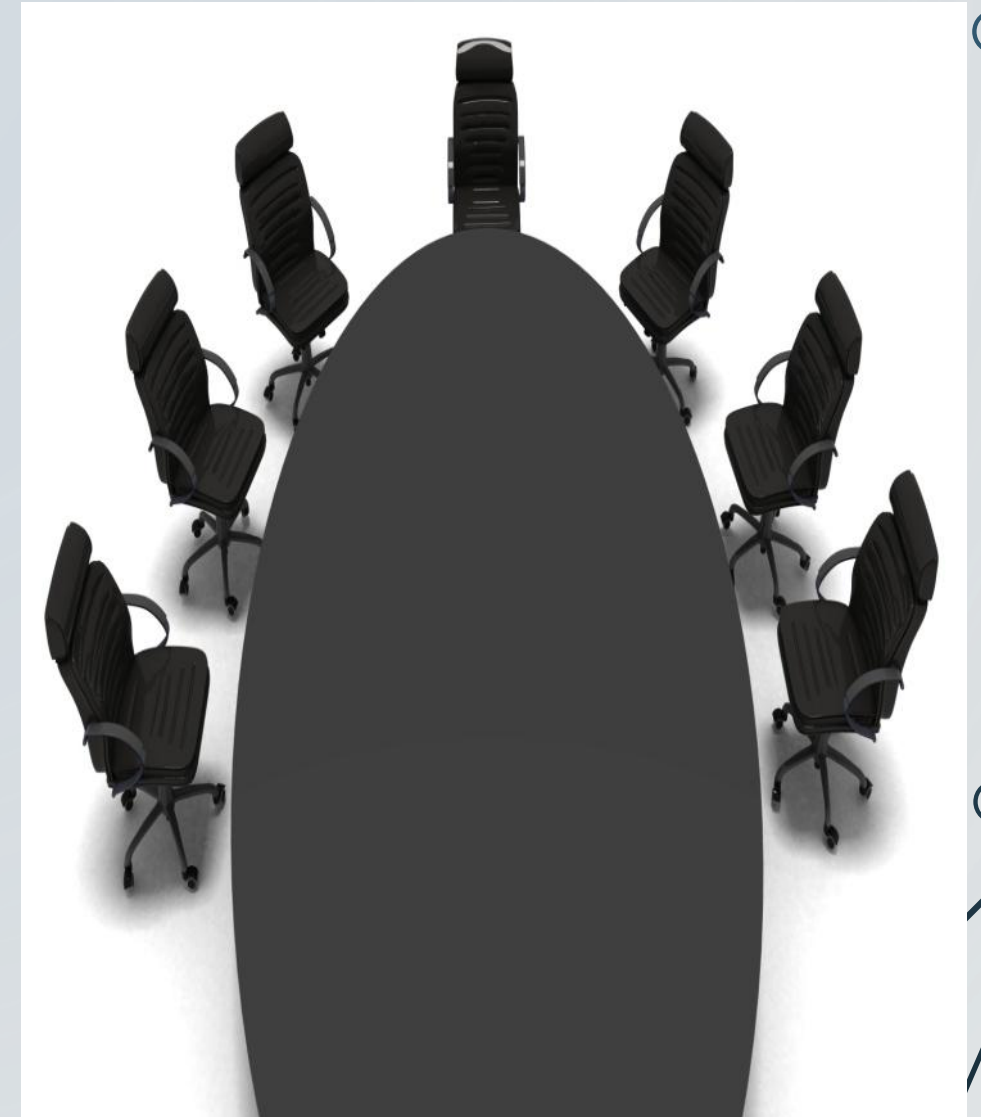
NECESIDAD DE UN SGSI

- El SGSI se exige en diversos puntos de la norma:
 - 4.1.2 Arquitectura de seguridad [op.pl.2].
 - La seguridad del sistema será objeto de un planteamiento integral detallando, al menos, los siguientes aspectos:
 - f) Sistema de gestión con actualización y aprobación periódica.
- ANEXO III: Auditoría de la seguridad
 - f) Que existe un sistema de gestión de la seguridad de la información, documentado y con un proceso regular de aprobación por la dirección.

EJERCICIO

Ejercicio 1:

- 1. ¿Crees necesario que tu empresa se certifique del ENS? Justifica la respuesta.*
- 2. ¿Qué medidas tomarías para que los empleados conocieran y cumplieran las políticas?*
- 3. ¿Qué es un SGSI? ¿Por qué es necesario implantarlo?*



4. PRINCIPIOS BÁSICOS DE ENS

- **Artículo 5: Principios Básicos del ENS:**
 - a) Seguridad integral.
 - b) Gestión de riesgos.
 - c) Prevención, reacción y recuperación.
 - d) Líneas de defensa.
 - e) Reevaluación periódica.
 - f) Función diferenciada.

4. PRINCIPIOS BÁSICOS DE ENS

Artículo 6. La seguridad como un proceso integral.

- Constituido por todos los elementos técnicos, humanos, materiales y organizativos, relacionados con el sistema.
- Concienciación de las personas

Artículo 7. Gestión de la seguridad basada en los riesgos.

- El análisis y gestión de riesgos permanentemente actualizado.
- Mantenimiento de un entorno controlado, minimizando los riesgos hasta niveles aceptables.

Artículo 8. Prevención, reacción y recuperación.

- Prevención: eliminar o reducir la posibilidad de amenazas
 - la disuasión y la reducción de la exposición.
- Detección y reacción, incidentes de seguridad se atajan a tiempo.
- Recuperación: restauración de la información y los servicios
- Garantía de conservación de los datos e informaciones en soporte electrónico.

4. PRINCIPIOS BÁSICOS DE ENS

- **Artículo 9. Líneas de defensa.**
- Estrategia de protección → múltiples capas de seguridad
- Si una falla:
 - a) Ganar tiempo para una reacción adecuada.
 - b) Reducir la probabilidad de que el sistema sea comprometido.
 - c) Minimizar el impacto final sobre el mismo.
- Las líneas de defensa han de estar constituidas por medidas de naturaleza organizativa, física y lógica.
- **Artículo 10. Reevaluación periódica.**

4. PRINCIPIOS BÁSICOS DE ENS

- **Artículo 11. La seguridad como función diferenciada.**
- Diferenciado el responsable de la información, del servicio y de la seguridad.
- Seguridad de sistemas de Información <> de prestación de servicios.
- La política de seguridad de la organización
 - Atribuciones de cada responsable
 - Mecanismos de coordinación y resolución de conflictos.

Artículo 12. Requisitos mínimos de seguridad.

• Obligatoriedad de **Política de seguridad**:

- a) Organización e implantación del proceso de seguridad.
- b) Análisis y gestión de los riesgos.
- c) Gestión de personal.
- d) Profesionalidad.
- e) Autorización y control de los accesos.
- f) Protección de las instalaciones.
- g) Adquisición de productos.
- h) Seguridad por defecto.
- i) Integridad y actualización del sistema.
- j) Protección de la información almacenada y en tránsito.
- k) Prevención ante otros sistemas de información interconectados.
- l) Registro de actividad.
- m) Incidentes de seguridad.
- n) Continuidad de la actividad.
- o) Mejora continua del proceso de seguridad.

5. REQUISITOS MÍNIMOS DE SEGURIDAD

- **Artículo 12. Organización e implantación del proceso de seguridad**

- Seguridad aplicable a todos los miembros de la organización

- **Artículo 13. Análisis y gestión de los riesgos**

- Realización de un análisis y tratamientos del sistema según una metodología conocida.
Ej: Magerit

- **Artículo 14. Gestión de personal.**

- Personal Información y Sistemas formado.
- El significado y alcance del uso seguro → normativa de seguridad
- Cada usuario identificado de forma única: Autenticidad y trazabilidad

- **Artículo 15. Profesionalidad.**

- Seguridad gestionada → personal cualificado.
- Exigencia a empresas proveedoras de seguridad de profesionales cualificados.

5. REQUISITOS MÍNIMOS DE SEGURIDAD

- **Artículo 16. Autorización y control de accesos**
 - Acceso a los SI controlados y limitados a usuarios permitidos.
- **Artículo 17. Protección de las instalaciones**
 - Áreas separadas para los SI, cerradas y con control de acceso.
- **Artículo 18. Adquisición de productos de seguridad y contratación de servicios de seguridad**
 - Adquisición de productos de seguridad según categorización del sistema y nivel de seguridad determinados.

5. REQUISITOS MÍNIMOS DE SEGURIDAD

- **Artículo 19. Seguridad por defecto.**

- El sistema proporcionará la funcionalidad mínima requerida para alcanzar los objetivos de la organización.
- En explotación se desactivarán por “control de la configuración” las funciones innecesarias
- El uso ha de ser sencillo y seguro, una utilización insegura requiera de un acto consciente

- **Artículo 20. Integridad y actualización del sistema**

- Conocer el estado de seguridad de los sistemas.

5. REQUISITOS MÍNIMOS DE SEGURIDAD

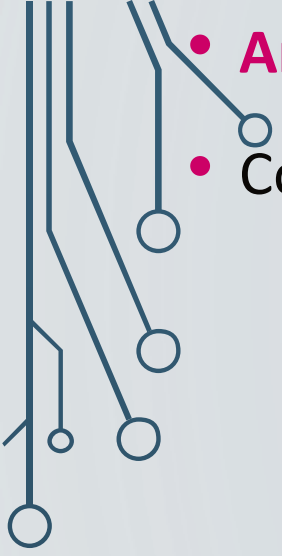
- **Artículo 21. Protección de la información almacenada y en tránsito**
 - Prestar especial atención a información almacenada.
- **Artículo 22. Prevención ante otros sistemas de información interconectados.**
 - Protección del perímetro del SI, sobretodo si está interconectado a redes públicas.
- **Artículo 23. Registro de actividad.**
 - Registro de las actividades para monitorizar, analizar, investigar y documentar actividades indebidas o no autorizadas.
- **Artículo 24. Incidentes de seguridad.**
 - Se establecerá un sistema de detección y reacción frente a código dañino.
 - Se dispondrá de un procedimiento de gestión de incidentes de seguridad y debilidades detectadas en los SI.

5. REQUISITOS MÍNIMOS DE SEGURIDAD

- **Artículo 25. Continuidad de la actividad.**
 - Copias de seguridad y mecanismos para garantizar la continuidad de las operaciones
- **Artículo 26. Mejora continua del proceso de seguridad.**
 - Criterios y métodos nacional e internacional relativos a gestión de las tecnologías de la información.
- **Artículo 27. Cumplimiento requisitos mínimos**
 - Redacción “Declaración de Aplicabilidad” de las medidas seleccionadas del Anexo II
 - Declaración firmada por el responsable de seguridad
- **Artículo 28. Infraestructuras y servicios comunes**
 - Determinados por cada administración

5. REQUISITOS MÍNIMOS DE SEGURIDAD

- **Artículo 29. Instrucciones técnicas de seguridad y guías de seguridad.**
 - El Centro Criptológico Nacional elabora guías de seguridad TIC de consulta.
- **Artículo 30. Sistemas de información no afectados.**
 - Si no permite el ejercicio de derechos ni con el cumplimiento de deberes por medios electrónicos
 - Si no facilita el acceso por medios electrónicos de los ciudadanos a la información y al procedimiento administrativo



• **Artículo 31. Condiciones técnicas de seguridad de las comunicaciones electrónicas.**

- Constancia de
 - la transmisión y recepción,
 - de sus fechas,
 - del contenido integro de las comunicaciones
 - y la identificación fidedigna del remitente y destinatario de las mismas.

• **Artículo 32. Requerimientos técnicos de notificaciones y publicaciones electrónicas.**

- Aseguren la autenticidad del organismo que lo publique.
- Aseguren la integridad de la información publicada.
- Dejen constancia de la fecha y hora de la puesta a disposición del interesado y del acceso a su contenido.
- Aseguren la autenticidad del destinatario de la publicación o notificación.

• **Artículo 33. Firma electrónica.**

7. AUDITORÍA DE LA SEGURIDAD

Artículo 34. Auditoría de la seguridad

- Sistemas de información deberán realizar una auditoria (al menos cada 2 años) de verificación de cumplimientos de los requerimientos del ENS
- En función de la categoría del sistema

8. ESTADO DE SEGURIDAD DE LOS SISTEMAS

- **Artículo 35. Informe del estado de la seguridad**
 - Conocimiento regular del estado de las principales variables de la seguridad de los SI

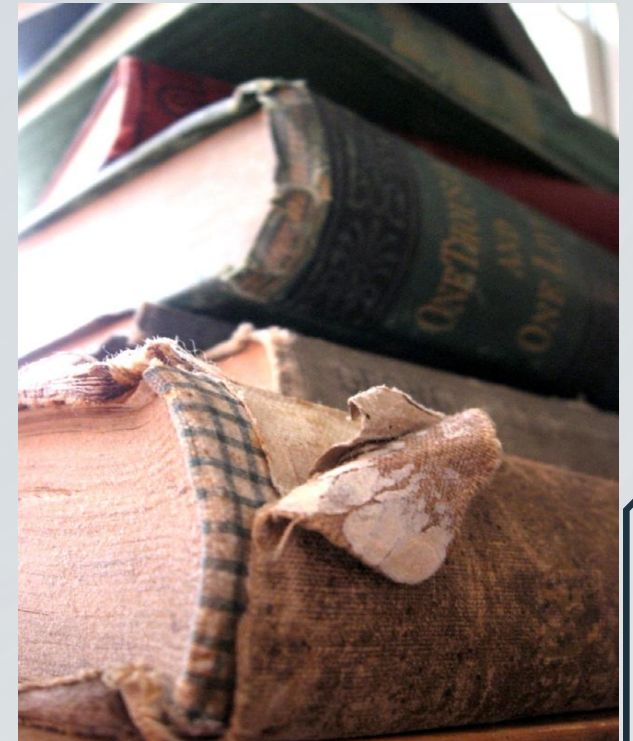


POLÍTICA DE SEGURIDAD

OBJETIVO: Dirigir y dar soporte a la gestión de la seguridad de la información en concordancia con los requerimientos del negocio, las leyes y las regulaciones.

La gerencia debería:

- Establecer una política de actuación
- Manifestar su apoyo y compromiso a la seguridad de la información



CONTENIDO DE UNA POLÍTICA DE SEGURIDAD

La Política de Seguridad debería contener enunciados relacionados con:

- Definición de seguridad de la información.
- Objetivos y alcance generales.
- Principios de seguridad
- Controles y análisis de riesgos.
- Políticas, estándares y requerimientos de la seguridad.
- Responsabilidades para la gestión de la seguridad.

NORMATIVA DE SEGURIDAD

La normativa de Seguridad puede detallar reglas sobre:

- Estructura del sistema documental
- Organización de la Seguridad de los SI
- Gestión de Activos
- Seguridad de los RRHH
- Seguridad Física
- Gestión de comunicaciones y operaciones
- Control de acceso
- Gestión de incidentes de SI
- Cumplimientos legales